

ISC 2019 第七届互联网安全大会

黑客心理学-社会工程学原理

杨义先

北京邮电大学教授

小鹅助理



扫码添加小鹅助理，与数万科技圈人士
分享重量级活动PPT、干货培训课程、高端会议免费
门票



黑客心理学 -----社会工程学原理

杨义先，教授
北京邮电大学信息安全中心主任





第七屆國際科學中心大會

Science Talk

笑谈科学 | Professor Yang





网络安全系列

— Hacker Psychology —

黑客心理学

社会工程学原理

杨义先 钮心忻 著



中国工信出版集团 电子工业出版社



第1届国际可信计算大会



补天系列丛书



第七届中国网络安全大会

“补天系列丛书”的体系

《安全简史》：风趣幽默的安全科普；增强全民对抗黑客攻击，整体全面提高网络安全强度。外行不觉深，内行不觉浅

《博弈系统论》（待出版）：黑客行为预测与管理

《安全通论》：在理工科范围内（不含心理学、社会学、经济学、管理学等），几乎没有任何限制（如设备、环境和人员等）的前提下，揭示黑客攻防和安全演化的基本规律。这些规律可以适用于网络空间安全的各主要分支

《黑客心理学》：1）填补全球信息安全界的一个重大空白，努力实现人、网、环境“闭环系统”全方位安全。2）提高全民的防骗、防黑客意识和水平。

《黑客心理学》小结

攻城为下，攻心为上；
攻网为下，攻人为上。
如何攻城，假假真真；
如何攻人，社会工程。

因此，本书的副标题叫“社会工程学原理”，即，从原理层次，穷尽所有可能的社工手段。



第七届中国信息安全大会

《黑客心理学》的背景（1）

- 所有信息安全问题，全都归罪于人！具体地说，归罪于三类人：破坏者（黑客）、保卫者（红客）和使用者（用户）。
- 但全球信息安全界，几乎都聚焦于网络或环境安全，而忽略了一个最关键的事实：**黑客是人**
- 反而是黑客们，常常基于心理学成果，利用“社会工程学”（简称“社工”），来攻击“人”；并以此为突破口，结合各种技术和非技术手段，把用户和红客打得落花流水
- “人”只不过是木偶，而人的“心理”才是拉动木偶的那根线；或者说，“人”只不过是“魄”，而“心理”才是“魂”

《黑客心理学》的背景（2）

- 所以，网络空间安全的根本核心，其实隐藏在人的心里。因此，《黑客心理学》希望借助心理学、社会学，来揭示信息安全的人心奥秘！
- 《黑客心理学》希望穷尽所有社工攻击的基本“元素”，即，所有无数种社工攻击方法，都只是这些有限个“元素”的某种融合而已。就像门捷列夫元素周期表中有限（数百）种元素，就能组成宇宙中无数种物质一样；实际上，社工攻击“元素”也只有数百种，被黑客常用的就更少了。



第七届中国信息安全大会

《黑客心理学》的背景（3）

- 在人、网、环境的闭环系统中，后两者“没天敌”，只需不断“水涨船高”就行；但是，人是有天敌的，人性的弱点有许多共同处，很难“打补丁”
- 总之，赢人者，赢天下；胜人者，胜世界！
- 由于“三种人”的目标、地位和能力等各不相同，所以，在网络空间安全攻防过程中，他们的心理因素也会不同。《黑客心理学》将重点探索最具网络特色的黑客心理，因为，若无黑客，几乎就没有安全问题。但遗憾的是，黑客过去存在，现在存在，今后也将永远存在；甚至还可能越来越多



第七届中国安全大会

与安全密切相关的心理因素（1）

- 性格与安全：下面8种性格，不利于安全：
 - 第1），攻击型性格。
 - 第2），性情孤僻、固执、心胸狭窄。
 - 第3），性情不稳定，易受情绪感染支配，易于冲动，情绪起伏波动很大，受情绪影响长时间不易平静
 - 第4），心境抑郁，浮躁不安者
 - 第5），马虎、敷衍、粗心
 - 第6），危急关头，惊慌失措、优柔寡断、鲁莽行事
 - 第7），感知、思维、运动迟钝、不爱活动、懒惰者
 - 第8），懦弱、胆怯、没主见者。



与安全密切相关的心理因素（2）

- 能力与安全：
 - 只有当能力与任务难度匹配时，才不容易出现安全问题。思维能力强的人，在面对重复的、一成不变的、不需动脑筋的简单操作时，就会感到单调乏味；从而埋下安全隐患。反之，能力较低的人，在面对力所不及的任务时，就会感受到无法胜任，甚至会过度紧张；从而，也容易引发安全问题。
- 情绪、情感与安全：
 - 积极情绪，可加深安全重要性认识，具有“增力作用”，能激发安全动机，采取积极态度。而消极情绪，会使人带着厌恶的情感去看待安全，具有“减力作用”，采取消极的态度，从而容易引发不安全行为。

与安全密切相关的心理因素（3）

- 意志与安全：
 - 意志对安全行为，起着重要的调节作用，主要是：合理控制情绪，克服不利于安全的心理障碍，并调动有利于安全的心理因素，坚持不懈地实现安全目标。
- 感知觉与安全：
 - 安全预防的水平，首先取决于对风险的认识水平；对风险认识越深刻，出现问题的可能性就越小
- 个性心理与安全：
 - 不良的个性心理特征，常是引发安全问题的直接原因。比如，有的认真负责，有的马虎敷衍；有的谨慎细心，有的粗心大意。对待前人的安全经验，有的不予盲从，事实求是；有的不敢抵制，违心屈从。等

与安全密切相关的心理因素（4）

- 气质与安全：
 - 有些工作，比如，个性化较强的OA类开发，需要反应迅速、动作敏捷、活泼好动、善于交际的人去承担。有些工作，比如，软件漏洞检测等，则需要仔细的、情绪比较稳定的、安静的人去做。等
- 个性对不安全行为的影响，主要表现在两方面：
 - 1），态度的影响。
 - 2），动机的影响。
- 行为退化对安全的影响：
 - 比如：若劳动时间太长，就会产生疲劳；若生活节律被干扰，就不能有效发挥体能；若失去完成任务的动力，就会懒散懈怠；若缺乏鼓励，就会泄气；若突然面对危险，就会产生应激反应等



第七届中国国际安全大会

与安全密切相关的心理因素（5）

- 失误与安全的关系及影响：
 - 第1，失误是不可避免的副产物，失误率可以测定。
 - 第2，工作环境可以诱发失误；故可通过改善工作环境，来防止失误。
 - 第3，下级的失误，也许能反映上级的职责缺陷。
 - 第4，人的行为，反映其上级的态度；比如仅凭直觉去解决安全问题，或仅靠侥幸来维护安全，那迟早会出问题。
 - 第5，过时的惯例，可能促发失误。
 - 第6，不安全行为，是操作员促发的、直接导致危害的失误，属于失误的特例。级别越高的人，其失误的后果就越严重。



第九屆國際資訊安全大會

黑客攻击行为的分类

- 网络黑客攻击是指，违背他人意愿，采取信息手段等非身体接触方式，以伤害他人（的财产或心灵）为目标的行为。
- 无论攻击行为是发生在网上或网下，黑客行为的最终效果都主要体现在网络空间中
- 按攻击目的划分，黑客行为可大致归为四类：
 - 观点表达型
 - 情绪宣泄型
 - 利益诉求型
 - 网络犯罪型



第七届中国网络安全大会

黑客攻击行为的本能说

- 本能说认为：攻击行为是由基因设定的，与遗传相关，它是人类为确保自身安全而形成的一种本能；这种本能经长期进化而来，攻击性强的个体，往往更具生存优势，
- 因此，按照本能说
 - 黑客攻击是不可避免的
 - 对攻击行为可定期加以发泄；以无破坏性发泄方式，代替破坏性发泄方式。



第九屆資訊安全大會

黑客攻击行为的非本能说（1）

- 非本能说之“挫折理论”认为：
 - 攻击来源于挫折
- 挫折理论对网络安全的启发至少有：
 - 无论如何，都不要在网络中激发不必要的矛盾，更不要使任何人遭受不必要的挫折，这样便可大幅度地减少黑客的攻击行为。
 - 看来，构建和谐的网络社会，对信息安全也是很有利的嘛。



第七届中国网络安全大会

黑客攻击行为的非本能说（2）

- 非本能说之“社会学习理论”认为：
 - 人并不是生来就具有攻击能力的，这种能力必须通过学习才能获得。这种学习，是通过观察榜样的行为及其后果来实现的，故又称为观察学习。
 - 观察了他人的攻击行为及其后果后，人便会形成攻击的观念，并以此指导自己的攻击行为。
 - 所以，黑客的攻击行为，具有一定的传染性。



第七届中国网络安全大会

黑客攻击意愿的弱化

- 无害宣泄；
- 习得的抑制，即，指人们在社会生活中所学到的，对攻击行为的控制；主要指
 - 社会规范的抑制
 - 痛苦线索的抑制（想象被害者的惨状）
 - 对报复的畏惧等三点。
- 置换与替罪羊：当某人遭受挫折，但他又对施害者无可奈何时，就会通过别的方式满足自己的需求；
 - 方式之一，便是置换对象，攻击那些与施害者相似的对象

社工黑客攻击的特点（2）

- 社工攻击，正在成为黑客攻击的必备手段；甚至，在所有重大黑客事件中，社工攻击几乎都是先锋队的主力军。
- 社工攻击的另一突出特点是：若你不了解它，那它将威力无穷；若你知道它正在攻击你，那你一定会逢凶化吉。比如，当你知道正在接听的某个电话，是诈骗电话时；就算骗子再高明，你也不会上当，甚至还可以随心所欲地戏弄他一番。



第七届中国网络安全大会

社工黑客攻击的特点（3）

- 综合社工攻击的上述特点，请问：
 - 还有必要假装高雅，而对“社工攻击”不屑一顾吗？
 - 还能假装强大，而视“社工攻击”为无物吗？
- 若仅停留在外观，那“社工攻击”手段无穷无尽。就像站在分子层次，人类将永远无法知道“到底有多少种物质”一样；但若深入到人性的底层本质，便可穷尽组成所有无数种社工攻击的少数几个“元素”



第七屆國際網路安全大會

社工黑客如何看待个体（1）

- 回顾历史的有趣循环：当年，在心理学重大成果（发现了“反馈+微调+迭代”赛博链）的启发下，人类造“电脑”，当时的模特儿是“人脑”；然后，又造了电脑网络；
- 如今，社工黑客在攻击“人脑”时，又是采用“反馈+微调+迭代”的赛博攻击链，又是拿“电脑”当模特儿

社工黑客如何看待个体（2）

- 社工将人看“电脑”，由四部分组成：
 - 1）输入：包括外部输入（即，感觉等）、内部反馈输入（即，知觉、动机、情绪和情感等）、噪音输入（即，无意识等）；
 - 2）输出：信息输出（即，语言等）、行为输出、内部反馈输出（即，动机、知觉、情绪和情感等）、噪音输出（即，无意识等）
 - 3）存储：包括记忆、习惯、无意识等；
 - 4）处理：包括计算（即，思维、认知）、去噪（即，注意等）、优化（即，学习、发展）



第七届中国网络安全大会

社工黑客攻击人的思路

- 欲攻破人这个“热血电脑”，就必须使其信息失控；
- 欲使信息失控，只需攻破输入、输出、存储或处理四大部分中的任何一部分；
- 欲攻破任何一部分，就必须充分利用心理学家已揭示的人性弱点；
- 欲充分利用这些弱点，就必须：
 - 要么使攻击对象在赛博式反馈循环中被诱入歧途，
 - 要么截获并利用无意识的噪音输出等。
 - 至于如何达到这些目标，将是《黑客心理学》的任务，欢迎大家详细阅读。



第七届中国网络安全大会

社工黑客攻击群体的思路（1）

- 社工黑客只需要从信息的角度去观察“群体”，而没必要像心理学家那样去全面考虑“群体”。
- 如果组成某群体的个体之间，完全隔离，即，群体成员彼此没有任何信息的交往；那么，黑客便可把这种群体，看成一些独立的“热血电脑”的堆集。既可以独立地，分别攻破这些“热血电脑”；又可以找出他们的共同特点，然后“一箭多雕”。



第七届中国网络安全大会

社工黑客攻击群体的思路（2）

- 其实，绝大部分群体都应该是这样的：群体成员彼此之间，存在着或多或少的信息交流；因此，在社工黑客看来，群体只不过是“热血电脑”组成的网络而已；
- 总之，在社工黑客眼里，群体的信息交流架构，完全等同于众所周知的、由冷血电脑搭建的互联网的信息交流架构；因此，黑客可借用已经相当熟悉的、攻击冷血网络的思路，来攻击群体这个“热血网络”

社工黑客攻击群体的便利（1）

- 合群机会
 - 1) 合群倾向，有助于社工黑客“打入敌人内部”，从而有利于后续攻击；
 - 2) 充分合群后，群体成员之间会越来越趋同，从而有利于提高攻击效率，甚至：攻破一个成员后，与其相似的成员也将全被攻破；
 - 3) 充分合群后，群体中信息交流将更密切；
 - 故篡改、破坏或截获相关信息将更易；
 - 通过一台“热血电脑”做跳板，去远程攻击另一台“热血电脑”也更易；
 - 黑客隐身也更简单



第七届中国网络安全大会

社工黑客的漏洞思维（1）

- 在冷血网络的信息安全对抗中，黑客和红客的主要战场，可能要算“漏洞挖掘”了
- 既然社工黑客将人类个体看成“热血电脑”，将人类群体看成“热血网络”；所以，挖掘相应的人性漏洞，也是红黑双方信息安全对抗的核心战场
- 与冷血网络不同的是，许多热血漏洞，根本无法“打补丁”，因为，某些漏洞干脆就是人的本能或潜意识习惯



第七届中国信息安全大会

社工黑客的漏洞思维（2）

- 从漏洞角度看，社工黑客比纯技术黑客处于更有利的地位；换句话说，我们更应该重视如何对抗社工黑客。
- 幸好，社工黑客的攻击，几乎都是循环反馈的“赛博式”攻击，所以，只要在其攻击过程中的任何一个环节，挡住了黑客，就算红客成功
- 人性漏洞非常多：
 - 有输入漏洞
 - 输出漏洞
 - 处理漏洞
 - 存储漏洞等四大类漏洞



第七屆國際信息安全大會

社工黑客的战术清单

- 感觉漏洞的挖掘和利用
- 知觉漏洞的挖掘和利用
- 记忆博弈
- 情结博弈
- 注意控制
- 动机诱惑

微表情泄密

肢体语言泄密

姿势泄密

喜欢的引发和利用

利他与易控行为的利用

态度的控制

人际关系的利用和控制

小鹅助理



谢谢!

扫码添加小鹅助理，与数万科技圈人士
分享重量级活动PPT、干货培训课程、高端会议免费门票